

[doc. web n. 10104860]

Provision of November 14, 2024

Register of provisions

No. 760 of November 14, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting held today, attended by
Prof. Pasquale Stazione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, concerning
the protection of natural persons with regard to
the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing the
"Code regarding the protection of personal data,"
which includes provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter
the "Code");

HAVING REGARD to Legislative Decree No. 101 of August 10, 2018, containing
"Provisions for the adaptation of national legislation
to the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of
April 27, 2016, concerning the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive 95/46/EC";

HAVING REGARD to Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers assigned to the Guarantor for the
protection of personal data, approved by
resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web
No. 9107633 (hereinafter "Guarantor Regulation No.
1/2019");

HAVING REGARD to the documentation on file;
HAVING REGARD to the observations made by the Secretary
General pursuant to Article 15 of the Guarantor Regulation No. 1/2000 on the
organization and functioning of the office of the Guarantor for the
protection of personal data, doc. web No. 1098801;
Reporter Attorney Guido Scorza;

PREMISED

1. The violation of personal data

On XX, the Territorial Health Company

Fatebenefratelli-Sacco, hereinafter “Company,” notified the Authority, pursuant to Article 33 of the Regulation, of a personal data breach, supplemented on XX, concerning a cyber attack on its information systems. In particular, it was reported that the aforementioned attack, conducted by a group called Vice Society, was caused by ransomware malware that resulted in the “malfunctioning of the IT applications” and the “exfiltration of data that involved an area of a file server available to corporate users accessing through shared folders.”

Considering the high number of potentially affected individuals and the nature of the personal data subject to the breach, it was necessary to request information from the Company (notes of XX, XX, and XX) which provided feedback, respectively, with notes of XX and XX and XX. This was done to acquire, in particular, detailed elements regarding the circumstances in which the incident occurred and to outline its scope in terms of the volume of exfiltrated data, compromised workstations and/or servers, as well as to know the duration of the service disruption to users and the times for restoring the various services, the methods by which information was made available to the affected individuals, as well as the status of the progress of the adoption of technical and organizational measures to prevent similar future breaches.

2. The fact

Preliminarily, with the notification of XX, it was declared that the attack concerned the “corporate IT systems underlying the IT infrastructure related, in particular, to the infrastructures of the PPOO Fatebenefratelli, Sacco, Buzzi, and Macedonio Melloni which also impacts the functioning of all systems of the other 33 territorial locations. Machines of type XX were “attacked,” also compromising the virtualization infrastructures.” Subsequently, on XX, the Company updated the information regarding the breach, stating that the attack had been “executed by the group called Vice Society [...] the Authorities’ analyses showed traces related to a potential exfiltration of data that involved an area of a file server available to corporate users accessing through shared folders. This hypothesis was confirmed on XX, when the Postal Police identified an area of the dark web that contained the aforementioned informational assets” (see notifications of XX and XX, section XX, point XX). With a note of XX, the Company also stated that “in the early hours of XX (around 03:00 –

04:00), calls were received by the on-call technician of the information systems from users reporting a malfunction of the information systems. After conducting the initial analysis and understanding the level of severity, the specialists called in on-call proceeded to isolate the entire IT infrastructure from the public network, in order to interrupt any ongoing malicious actions. In the following hours, the published data. This allowed for a more comprehensive analysis of the information that had been compromised. The tools were designed to systematically navigate through the data leak site, capturing and categorizing the sensitive information that had been exposed.

In summary, the incident involved significant data exfiltration, affecting numerous systems and services within the organization. The response included immediate actions by cybersecurity specialists and law enforcement to assess the breach and mitigate its impact, with ongoing efforts to restore services and secure sensitive information.

The organization has committed to transparency regarding the incident and is taking steps to prevent future occurrences, including enhancing security measures and protocols. appropriate log file the entire DLS. The list of files was then analyzed, first with automated tools and subsequently verified by Information Systems operators, finding that the original structure was not maintained in the publication, thus making the classification of the exfiltrated information extremely complex. This procedure did not allow for a precise remapping of the published files with the content of the file server, as the names of the files and their respective paths underwent changes related to multiple platform conversions (file server, upload site, DLS, web crawler), effectively making it impossible to trace back to the original document with certainty. Furthermore, the large number of objects found and – above all – their heterogeneity did not allow for a direct and easy assessment of the type of information contained therein, since a thorough analysis of the documents would have required manual intervention by operators who would have had to open each individual file and ascertain its content in order to identify the subject involved. This operation would have required an enormous effort in terms of human resources engaged, which were not (and are not) available, as well as exposure to significant security risks given the nature of the DLS. In any case, the semi-automated analysis, based solely on the nomenclature of the objects and the partial structure of the files, allowed for an estimation (in a very approximate manner) of the following:

- personal data of citizens (several thousand) and employees (several hundred): personal data, domicile, residence, phone numbers of citizens and company employees (e.g., pay slips, cover letters, CVs);
- sensitive data of citizens (several thousand) and employees (several dozen): clinical data (e.g., reports, discharge letters, clinical studies, trials);
- judicial data of citizens (several hundred): judicial measures (e.g., court protocols)” (see pp. XX).

The Company also represented that “to have a more precise numerical estimate, based on the times found in the initial analysis and taking into account the extraordinary security measures that would need to be implemented, it is estimated that approximately 350 man-days of a resource dedicated to classifying the material would be required; (...) even the investigations initiated following the filing of the complaint by this ASST did not allow for the determination of the nature of the data taken; (...) the Judicial Police, from the nomenclature of the files, had deemed it possible to exclude the presence of health data of patients (...and) subsequently highlighted the publication of sensitive files on the dark web, but (...) the origin of the data has not been verified” and that from the request for archiving by the P.G., it appears that “the thorough investigations on the IT systems did not allow for tracing the origin of the cyber attack and that the users of the IT network involved in the attack had long been the subject of phishing campaigns aimed at unlawfully obtaining access credentials. Moreover, the author of the attacks resorted to “anti-forensics” techniques, deleting parts of the system logs, thus hiding the operations carried out on the attacked IT systems.” On the same occasion, it was also represented that “no compensation request has been made against this ASST by users/patients to whom the data

subject to violation could refer” (see note of XX, pp. XX).

3. The measures in place at the time of the violation

With reference to the technical and organizational measures in place at the time of the violation, the Company stated that “the infrastructure was equipped with perimeter protection systems, centralized authentication systems with password expiration rules XX, password complexity, non-repetition of passwords, presence of antivirus systems on all servers and all workstations, presence of XX, system XX on a limited number of servers, personal firewall systems on a limited number of workstations, VPN with access controlled by user and password. Furthermore, all systems were regularly subjected to backup according to predefined periodicity.” Additionally, information was provided to staff also through a Circular from the General Director regarding the rules of conduct to be followed for the use of company IT tools. It is also confirmed that, prior to the Covid pandemic period, basic IT training events were regularly organized in classrooms during which behaviors to adopt to avoid possible cyber violations (phishing emails, etc.) were also illustrated (see notifications of XX and XX, section XX point XX and note of XX, p. XX).

Regarding the IT authentication procedures used in accessing the VPN and workstations and the password policies provided for different types of users, the Company, in a note dated XX, stated that: - “at the time of the attack, two-factor authentication, although not implemented, was in the process of being activated (the activation request order was issued in XX and the measure was activated immediately upon the resumption of services after the cyber attack). Among the technical measures at the time of the attack, there was:

- presence of user credentials XX, characterized by complexity criteria, minimum length, non-repetition;
- individual authentication of technicians delegated by authorized software houses;
- limitation, for user groups, of access to navigation XX;
- presence of black list navigation sites;
- replacement and harmonization of corporate firewalls, with periodic patching activities and equipped with antivirus for perimeter control;
- presence of antivirus systems for client and server protection;
- presence of an antispam system on the email management system;
- activation (on a limited number of servers) of tools XX;
- classroom training courses in which, among other things, behaviors to adopt in case of phishing emails were illustrated;
- availability of a corporate WIFI coverage, XX, allowing internet access for a limited time session;
- gradual replacement of PCs with "thin client" devices (see pages XX).

Regarding the technical and organizational measures adopted at the time of the violation on the file sharing system subject to violation and data exfiltration, the Company highlighted that “at the time of the violation, the following policy was in effect on the file sharing systems: access to folders was allowed, in read/write mode, to users authorized by the structure manager through the use of security groups managed at the domain level; all systems were subject to regular and constant backup, XX; this technical measure allowed for the total restoration of the systems, without any loss of informational assets; there was screening control on the types of files saved on the systems, to prevent users from saving files with disallowed extensions (e.g., XX); antivirus and antimalware systems were actively updated on the systems” (note of XX, page XX).

4. Measures Adopted Following the Violation

With reference to the measures adopted following the violation, the Company stated that “as soon as the attack was detected, all computer systems were shut down and the connectivity infrastructures were isolated. Furthermore, verification was carried out on the availability and integrity of the data in the backup subsystem as well as the restoration of the virtualization environments. Data and services are also being restored. Additionally, checks are ongoing on the logs of the devices and systems, with particular reference to the organization's security systems for a subsequent phase of analysis and correlation concerning any known IOCs. From an organizational standpoint, all ambulances were

immediately redirected to the emergency departments of other Health Authorities. Instructions were given to ensure the operation of hospital facilities and territorial offices through manual/local procedures” and that “the procedure for restoring the systems was activated in order to reactivate services for users and corporate operators. Checks on the logs of the devices and systems are still ongoing, particularly concerning the organization's security systems for a subsequent phase of analysis and correlation regarding any known indicators of compromise (...) as the systems are progressively restored, the situation has gradually returned to normal” (see notifications of XX and XX, section X, point XX).

In a note dated XX, in response to the information request from XX, the Company stated, in addition to what has already been declared, that:

“the operations related to the restoration of services followed a classification that prioritized the clinical-health area and, progressively, the administrative and technical services”;
following the reactivation of services in the clinical-health area “the various 'minor' systems were progressively restored, which, in some cases, also required the total reconstruction of the application server”;

“systems exposed on the internet, including the email service, were activated only after excluding the presence of malicious elements on the corporate network; these services were restored on the day XX, although internal email communications were initiated starting the previous week”;

the restoration of “file sharing, before being returned to users, was deliberately subjected to a detailed antivirus control process that involved every single file, in order to verify the absence of hidden or silent malware elements within the shared folders; considering the long times required for this area, the restoration of shared folders prioritized based on users (...)”;

“despite the absence of IT support, the functioning of essential services (emergency room, urgent admissions) was guaranteed with emergency procedures, in a context where the ASST had requested disconnection from the emergency-urgency circuit to avoid flows sent from the operations center”;

“among the technical measures already adopted before the attack and those activated during the post-attack restart, the following are highlighted: VPN access terminating on corporate firewall systems, based on two-factor authentication; periodic firmware updates of firewalls, especially during significant security patches; log analyzer on firewall systems; access to the XX desktop virtualization infrastructure (from outside the Company) based on two-factor authentication; extension and dissemination of tools XX on the server pool (XX and XX) and on the client pool; limitations on internet navigation; antivirus and personal firewall.”

**Operating on all workstations, as well as on the server park; deactivation of the possibility to forward the company email to an external mail server; segmentation of the network and segregation of areas through the implementation of DMZ on internal firewalls (e.g., XX, XX, etc.); initiation of a detailed management change that, for ICT suppliers, provides access to XX from which access to a limited number of directly managed servers is guaranteed; restructuring of servers supporting the company domain controllers; definition of a single corporate tool for remote control of workstations, used by both company personnel and IT suppliers; consolidation of automatic tools for the termination of accounts upon termination of the employment relationship (starting from employee registry); constant updating of PCs and servers of family XX through XX; periodic updating of XX; periodic updating of servers of family XX; gradual decommissioning of workstations with operating system XX; gradual replacement of PCs in favor of thin client devices; adoption of regulations for access to the SmartWorking institute, which regulates the times, methods, and tools for operating in this work mode; training events aimed at company, administrative, and healthcare personnel, held in the month of XX and XX, in which behaviors to adopt in risk circumstances were demonstrated; on this last point, regional-level events are also planned; participation in a regional initiative aimed at defining tactical actions on security” (see pages XX).

With reference to the technical and organizational measures adopted to prevent similar future violations, the Company declared that it would increase “the security levels of infrastructures and services by introducing authentication systems with at least two factors, (...) the level of monitoring and security through the introduction of SIEM (Security Information Management) systems,”

segmented “the networks and communications” and that “at the regional level, a series of initiatives have been activated that, involving all Health Companies, aim to perform an analysis of the current situation, identify potential criticalities, and define strategies to remedy them. Specifically, among the measures already adopted, the following are highlighted:

- activation of VPN access based on two-factor authentication;
- activation of access to the desktop virtualization infrastructure based on two-factor authentication;
- extension and dissemination of tools XX on the server park (XX and XX) and on the client park;
- further limitation of internet browsing, which was already limited;
- reorganization of remote access methods, significantly limiting the use of the RDP protocol;
- restructuring of servers supporting the company domain controllers.

Other tools will also be activated, based on the aforementioned initiatives coordinated at the regional level, to increase the level of security monitoring, including: identification of a security specialist who, within the regional initiative, will follow the ASST; SOC systems for 24/7 surveillance on company systems XX and antivirus; SIEM systems as a data correlation tool; further training events will be organized to further empower company personnel and users” (see notifications of XX and XX, section XX, point XX).

In a note dated XX, the Company represented that “important initiatives have also been activated at the regional level that, involving all Health Companies, act on enhancing security; among these, the activation of a Security Operation Center (SOC) is of enormous importance, which, through specific 24/7 monitoring activities on the XX systems of Lombardy Health Companies, oversees potential risk events at the inter-company level. Among the measures planned for activation during the years XX: activation of a Security Information and Event Management (SIEM) as a tool for correlating various logs collected from servers, network devices, antivirus, XX, etc.; training events aimed at all company personnel regarding basic IT, use of IT tools, use of email, and potential threats; activation of two-factor authentication on the XX email client for external access; access to company email from mobile devices, decoupled from the company domain account; drafting of a document for managing IT incidents; drafting of a new regulation for the use of company electronic tools.”

5. ****Office Evaluations on the Treatment Performed and Notification of the Violation Pursuant to Article 166, Paragraph 5 of the Code****

Regarding the described case, the Office, based on what was represented by the data controller in the notification of the violation and in responses to the Authority's requests for information, as well as subsequent evaluations, notified the same data controller, pursuant to Article 166, Paragraph 5, of the Code, of the initiation of a procedure for the adoption of measures referred to in Article 58, Paragraph 2, of the Regulation, inviting the same to submit defensive writings or documents to the Guarantor or to request to be heard by the Authority (Article 166, Paragraphs 6 and 7, of the Code; as well as Article 18, Paragraph 1, of Law No. 689 of November 24, 1981). In particular, with act No. XX of XX, the Authority has determined that the Company had engaged in processing activities in violation of the principle of "integrity and confidentiality," as stated in Article 5, paragraph 1, letter f), of the Regulation, as well as the obligations regarding the security of processing (Article 32 of the Regulation).

The same Company submitted its defensive memoranda, pursuant to Article 166, paragraph 6, of the Code. In particular, in a note dated XX, it specified what had already been communicated, stating that: - "An essential element for evaluating the event is the nature of the triggering factor of the violation, which in this case is the unlawful action carried out by the organization known as 'Vice Society,' composed of expert hackers who attacked the ASST using advanced techniques and methods that are complex to prevent as well as to detect. Indeed, even specialized entities in managing and identifying hacker attacks (such as those that occurred at the ASST systems: specialists from the Cyber Security Operations Center of ARIA SpA, agents from the Postal and Communications Police, specialists from the National Cybersecurity Agency) were unable to fully reconstruct the event and, therefore, to identify the attack vector. Neither the Judicial Police was able to ascertain its origin, precisely due to the techniques employed by the perpetrators, who – as established by the investigators – resorted to 'anti-forensics' techniques, deleting parts of the system logs and thus concealing the operations carried out on the attacked IT systems. Therefore, the difficulties for an entity like ASST Fatebenefratelli

Sacco in facing such organized and orchestrated attacks are indisputable, considering the extremely high number of personnel employed in the use of corporate information systems and the economic resources available; (...) all the hardening activities of the IT systems and corporate networks that have been conducted over the years prior to the attack were developed concurrently with the COVID emergency which, during the years XX and XX, significantly impacted the information systems, which were called upon to automate processes and innovate 'business-critical' clinical departments in an ad-hoc manner and with very rapid timelines, in a context where the technical-IT workforce did not experience concurrent increases. It should be noted, in fact, that the Sacco Hospital of the Company is a national reference center for infectious disease emergencies";

- "for this purpose, various services to citizens were activated during the two-year period XX-XX, while simultaneously ensuring the maintenance of all existing services. By way of example, it is noted that: numerous services provided 'at the counter' were dematerialized and conveyed through information systems, often developing in-house applications (service provision choice/revocation, vaccination management, disabled student portal, etc.); reporting systems, especially those in the laboratory area, worked continuously and at sustained rates to provide, in real-time, the results of swabs to citizens as quickly as possible; during XX, the ASST was called upon to activate, in record time, a 'ad-hoc' vaccination center at the 'Fabbrica del Vapore' location, which performed over 400,000 vaccinations operating seven days a week; for several hundred employees, a 'smartworking' mode was activated to ensure the operability of central functions even during the lockdown period; some healthcare services were provided via teleconsultation, requiring a prompt adjustment of corporate systems, as well as network infrastructures";

- "during the pandemic period, there were (...) hundreds of massive phishing campaigns directed at the corporate domain, thwarted thanks also to the constant 'reprogramming' of the email management systems by the corporate system administrators. It is in this context, where the ICT personnel experienced a prolonged situation of stress and high workloads, that the hacker attack by the 'Vice Society' group occurred";

- "only an attack carried out by an organization with criminal intent, moreover in a context of significant organizational and managerial difficulties due to the state of emergency related to the COVID-19 epidemic (an additional external factor not dependent on the will of the ASST), led to the violation in question";

- "the Data Controller, at the time of the violation, had in place:

perimeter protection systems;

centralized authentication systems with password expiration rules XX, with password complexity, non-repetition of passwords;

antivirus systems on all servers and all workstations;

XX, system XX on a limited number of servers;

personal firewall systems on a limited number of workstations;

VPN with access controlled by user and password;

all systems were regularly backed up according to predefined frequency;

individual authentication of technicians delegated by authorized software houses;

limitation, for user groups, of access to XX browsing;

presence of blacklists for browsing sites;

replacement and harmonization of corporate firewalls, with periodic patching activities and equipped with antivirus for perimeter control;

presence of an anti-spam system on the email management system;

availability of a corporate wifi coverage, XX, allows internet access for a timed session." limited;

progressive replacement of PCs with thin client devices;

- "regarding file sharing systems, the ASST had adopted the following policy: access to folders was allowed, in read/write mode, to users authorized by the structure manager through the use of security groups managed at the domain level; all systems were subject to regular and constant backup XX; this technical measure allowed for the complete restoration of the systems, without any loss of informational assets; there was screening control on the types of files saved on the systems, to

prevent users from saving files with unauthorized extensions (e.g., XX); antivirus and antimalware systems were constantly updated and active on the systems”;

- “regarding the personnel involved in the processing activities using the systems involved in the breach, the Data Controller had implemented the following measures: classroom training courses in which, among other things, behaviors to adopt in case of phishing emails were illustrated; information to personnel also through a Circular from the General Director regarding the rules of conduct to be followed for the use of corporate IT tools;

- “moreover, (...), although not yet active at the time of the attack suffered, the ASST had already arranged for the activation of two-factor authentication systems, thereby demonstrating that the Data Controller had set up a path for the implementation of measures that, in this case, were not applied solely due to the timing factor”;

- “regarding the severity of the breach, while taking into account the quantity and type of data that were breached and the fact that among the affected individuals there are also vulnerable persons (minors and patients in precarious health conditions), the Data Controller believes that – particularly with regard to the potential impact on the affected individuals – it can be classified as ‘medium’; it should be noted that the different qualification of severity compared to that initially hypothesized by the Data Controller in the notification to the Authority (severity ‘high’, both concerning the ‘potential impact on the affected individuals’ and regarding the ‘high risk to the rights and freedoms of natural persons’) can be supported for the following reasons that emerged subsequent to the aforementioned notification: 1) From the results of the investigations carried out, it emerges that the data published on the dark web is actually difficult to view and consult. From the request for the archiving of the criminal proceedings initiated following the complaint filed by the Entity (document on file with the Authority), it can be inferred that the Judicial Police, from the nomenclature of the files stolen, initially even believed they could exclude the presence of health data of patients. The same P.G., (...), subsequently highlighted the publication of sensitive files on the dark web, but the origin of the data has not been verified. 2) Almost two years after the publication of the data on the dark web, no compensation requests have been made against the company by users/patients to whom the data subject to the breach could refer; it can therefore be reasonably assumed that no serious injuries to the rights and interests of the natural persons involved in the breach have occurred. 3) Following the restoration procedures of the operability of the systems arranged by the Data Controller, the informational assets have been restored to the situation quo ante the attack. 4) The restoration of all services temporarily affected by the attack was carried out quickly and without evident negative consequences (neither for the Company nor for the users), especially regarding essential services related to: technological infrastructure; basic and integration systems (XX, XX, XX, etc.); clinical-healthcare systems (Emergency Room, Hospital Management, Outpatient Reporting, CUP, etc.); diagnostic systems (Radiology, Laboratories, etc.); which were progressively restored in a few days (operations completed on XX), thereby ensuring that the facilities could continue their operations without limitation and avert risks to the health and safety of patients”;

- “information (...) was provided to the public regarding the attack suffered by the company (‘Notice of attack on corporate information systems’ – posted on XX

<https://www.asst-fbfsacco.it/news/info/avviso-attacco-ai-sistemi-informativi-aziendali> - Provisional Register, modified on XX <https://www.asst-fbf-sacco.it/pages/albopretorio-provvisorio>) information on XX to the affected individuals through publication on the institutional website of a note informing citizens of the incident and the security measures adopted to mitigate the negative effects on the affected individuals.” On XX, the hearing requested by the Company took place, during which it clarified that:

- “the criminal group VICESOCIETY had launched attacks on ABI and also on other public and healthcare organizations about two months prior; the atypicality of the attacker’s behavior was noted in relation to the publication of files on the dark web approximately 50 days after the attack itself and not immediately after the expiration of the ransom request, as is generally the case”;

- “criminal activities began some time before the occurrence of the attack (presumably a year), when the Company was subject to intense SPAM and phishing campaigns and employees were carrying out.”

the context of the processing activities in question, it is determined that the processing carried out does not meet the required standards of security as mandated by the applicable regulations. The lack of adequate technical and organizational measures has resulted in a significant risk to the confidentiality, integrity, and availability of personal data, particularly sensitive data related to health.

8. Recommendations for Compliance

In light of the findings, it is recommended that the Company take immediate action to implement the following measures:

- Conduct a comprehensive risk assessment to identify vulnerabilities in the current data processing activities.
- Enhance security protocols, including the implementation of multi-factor authentication (MFA) and network segmentation, to better protect personal data.
- Establish a robust incident response plan to ensure timely detection, reporting, and management of data breaches.
- Provide regular training for employees on data protection and cybersecurity best practices to mitigate risks associated with human error.
- Ensure ongoing monitoring and auditing of data processing activities to maintain compliance with regulatory requirements.

9. Final Remarks

The Company is urged to prioritize the protection of personal data and to take the necessary steps to align its practices with the legal obligations set forth in the applicable data protection regulations. Failure to do so may result in further legal consequences and reputational damage. The importance of safeguarding personal data, especially sensitive information related to health, cannot be overstated, and the Company must act decisively to rectify the identified deficiencies.

****8. Adoption of the injunction order for the application of the administrative sanction****

Except where the act constitutes a more serious offense, anyone who, in a proceeding before the Authority, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Authority and interruption of the execution of the tasks or the exercise of the powers of the Authority." The elements provided by the data controller in the aforementioned defensive memorandum, although deserving of consideration, do not allow for overcoming the observations notified by the Office with the aforementioned initiation act of the procedure, nor do any of the cases provided for in Article 11 of the Authority's Regulation No. 1/2019 apply.

From the examination of the information and elements acquired as well as the documentation provided, the processing carried out by the Company is found to be unlawful, as it was carried out in violation of Articles 5, paragraph 1, letter f) and 32 of the Regulation, in relation to the aspects reported below.

****7.1. Failure to adopt adequate measures to timely detect personal data breaches****

During the investigation, it emerged that "from the logs in possession of ASST [...], the compromise activity had been dormant from a prior moment and manifested itself with the attack of XX. It was not possible to trace back to the attack vector" (see notification of XX, section XX, point XX), and that "from the analyses, an activity of data exfiltration was detected which, having started before the date of the attack, targeted a server used for file sharing, transferring data to the file transfer platform called MegaUpload." Furthermore, "on a limited number of servers [...] tools XX were active" (see note of XX, page XX) and, following the attack, ASST deemed it necessary, among other measures, to equip itself with a "Security Information and Event Management (SIEM) as a tool for correlating the various logs collected from servers." The above has highlighted a deficiency in the adoption of measures that did not allow the Company to detect and become timely aware of the personal data breach that occurred.

The failure to adopt adequate measures to timely detect personal data breaches does not comply with the provisions of Article 5, paragraph 1, letter f), and Article 32, paragraph 1, of the Regulation which, in the case at hand, taking into account the provisions of the aforementioned Guidelines, requires that

the data controller and the data processor must implement measures to "identify [...] a breach in a timely manner."

****7.2. Failure to adopt adequate measures to ensure the security of systems and networks****

During the investigation, it emerged that the Company had not adopted adequate measures to segment and segregate the networks on which the workstations of its employees were located, as well as the systems (servers) used for processing. In relation to this aspect, the Company, following the incident, deemed it necessary to proceed with the "segmentation of the network and segregation of the areas through the implementation of DMZ on internal firewalls."

Moreover, at the time the personal data breach occurred, remote access via VPN to the Company's network was carried out through a computer authentication procedure based solely on the use of username and password. In relation to this aspect, the Company specified that "at the time of the attack, two-factor authentication, although not implemented, was in the process of being activated (the activation request order was issued on XX and the measure was activated immediately upon the resumption of services after the cyber attack)."

The failure to implement, at the time of the breach, adequate measures to ensure the security of networks and the failure to adopt a two-factor authentication system does not fully comply with the provisions of Article 5, paragraph 1, letter f), and Article 32, paragraph 1, of the Regulation which, in the case at hand, requires that the data controller must implement measures to "ensure on a permanent basis the confidentiality, integrity, availability, and resilience of processing systems and services" (letter b)).

In this regard, the fact that, at the time of the incident, the Company had initiated some interventions aimed at strengthening authentication procedures - although deserving of consideration for the evaluation regarding the principle of data protection by design and data protection by default (Article 25 of the Regulation) - cannot be deemed sufficient to exclude a violation of Article 32 of the Regulation. This is because the worsening of the cyber risk, also resulting from the spread, during the COVID-19 pandemic, of modes and technological tools to allow remote execution of activities (both work-related and otherwise), was already foreseeable at the time of the breach. Therefore, considering the significant increase in attacks by cybercriminals, especially against healthcare structures, the Company should have continuously updated, over time, the security assessment, in order to weigh the new and much more serious risks associated with processing for the rights and freedoms of the data subjects in relation to the adequacy of the measures adopted (due to the nature of the data processed, the large scale of the data subjects involved, including vulnerable individuals, as well as the possible negative consequences for them).

It is believed that the conditions of Article 17 of the Authority's Regulation No. 1/2019 are met. financial penalty and accessory sanctions (art. 58, par. 2, lett. i and 83 of the Regulation; art. 166, comma 7, of the Code).

The violation of art. 5, par. 1, lett. f) and 32 of the Regulation, caused by the conduct carried out by the Company, results in the application of the administrative pecuniary sanction pursuant to art. 83, par. 4 and 5 of the Regulation.

The Authority, pursuant to art. 58, par. 2, lett. i) of the Regulation and art. 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to article 83, in addition to (other) (corrective) measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case," by adopting an injunction order (art. 18 of law 24 November 1981, no. 689), in relation to the processing of personal data carried out by the Company, which has been found to be unlawful, as stated above.

It is deemed necessary to apply par. 3 of art. 83 of the Regulation where it provides that "if, in relation to the same processing or related processing, a data controller [...] violates, with intent or negligence, various provisions of this Regulation, the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation," the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same art. 83, par. 5.

In light of the above and, in particular, of the category of personal data involved in the violation, which, by their nature, are particularly sensitive in terms of fundamental rights and freedoms, it is considered that the level of severity of the violation committed by the Company is high (cf. European Data Protection Board, "Guidelines 04/2022 on the calculation of administrative fines under the GDPR" of 23 May 2023, point 60), despite the unintentional nature of the violation (the incident appears to have been caused by fraudulent behavior on the part of a third party, formally reported to the postal police). That said, certain elements are assessed as a whole, in particular that:

- the Authority became aware of the event following the notification of the violation made by the Company, pursuant to art. 33 of the Regulation and no complaints or reports regarding the violation subject to this provision have been received (art. 83, par. 2, lett. h) and k) of the Regulation);
- the Company, in order to prevent the recurrence of the event that occurred, has committed to strengthening specific measures and has cooperated with the Authority at every stage of the investigation, in order to remedy the violation and mitigate its possible negative effects (art. 83, par. 2, lett. c) and f) of the Regulation);
- the attack occurred immediately after the end of the pandemic period, which affected the processes of adapting systems and training initiatives (art. 83, par. 2, lett. k) of the Regulation).

In light of the above-mentioned elements and the assessments made, it is deemed appropriate, in this specific case, to determine the amount of the pecuniary sanction at €40,000.00 (forty thousand/00) for the violation of arts. 5 and 32 of the same Regulation, based on the principles of effectiveness, proportionality, and deterrence to which the Authority must adhere, pursuant to art. 83, par. 1, of the Regulation.

In this context, it is also considered that, pursuant to art. 166, comma 7, of the Code and art. 16, comma 1, of the Authority's Regulation no. 1/2019, the publication of this section containing the injunction order on the Authority's website should proceed. This is due to the type of personal data subject to unlawful processing and the significant number of potentially affected individuals.

ALL OF THE ABOVE CONSIDERED, THE AUTHORITY

pursuant to arts. 57, par. 1, lett. f) and 83 of the Regulation, finds the unlawfulness of the processing carried out by the Territorial Social Health Company Fatebenefratelli-Sacco, with registered office at Via G.B Grassi no. 74, 20157 – Milan, Tax Code/VAT number 09319690963, as stated in the reasoning, for the violation of arts. 5 and 32 of the Regulation;

ORDERS

pursuant to art. 58, par. 2, lett. i) of the Regulation, the same Company, represented by the legal representative pro tempore, to pay the sum of €40,000.00 (forty thousand/00) as an administrative pecuniary sanction for the violation indicated in this provision.

ENJOINS

the aforementioned Company to pay the sum of €40,000.00 (forty thousand/00) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to art. 27 of law no. 689/1981. It is noted that pursuant to art. 166, comma 8 of the Code, the offender retains the option to settle the dispute by paying - always according to the methods indicated in the annex - an amount equal to half of the imposed sanction within the term provided for the filing of the appeal as indicated below, in accordance with art. 10, comma 3, of legislative decree 1 September 2011, no. 150.

DISPOSES

a) pursuant to art. 166, comma 7, of the Code and art. 16, comma 1, of the Authority's Regulation no. 1/2019, the publication of the injunction order on the Authority's website;

b) pursuant to art. 154-bis, comma 3 of the Code and art. 37 of the Authority's Regulation no. 1/2019, the publication of this provision on the website.
internet of the Authority;

c) pursuant to Article 17 of the Regulation of the Guarantor No. 1/2019, the annotation of violations and measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to file an appeal before the ordinary judicial authority,

under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, November 14, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE SECRETARY GENERAL

Mattei